

CRM Sync — Security Audit & Paired Data Requirements

The security audit and paired-data requirements: which data must travel together, and the controls that keep every pair consent-qualified.

Date: 2026-05-18 Version: 1.1 Worker Version: dac8f178-f6ed-4a11-96be-f640a67c64ae

1. SECURITY AUDIT SUMMARY

1.1 Route Auth Coverage (Post-Hardening)

All 67 routes verified. Every write endpoint and admin endpoint now requires authentication. Per-tenant admin keys provide granular access control with platform key fallback.

AUTH LAYERS

LAYER	MECHANISM	PROTECTS
Bearer Token	Authorization: Bearer <ADMIN_KEY> or per-tenant admin_key	All /admin/* , /sync/* , /config POST , /tags/create , /webhooks/upsell , /platform/config
Admin Key (query)	?key=<ADMIN_KEY> in URL	/setup , /onboarding , /onboarding/setup , /settings
JWT (user session)	httpOnly cookie, HS256 signed	/auth/me , /auth/profile , /auth/delete-account , /ucp/* , /tags/* , /segment/*
HMAC-SHA256	X-Shopify-Hmac-SHA256 header	/webhooks/customer-update , /webhooks/customer-create , /gdpr/* , /api/webhooks
OAuth State	UUID-keyed KV nonce (oauth_state:{uuid}), single-use, includes shop	/auth/callback , /auth/webflow/callback , /auth/google/callback , /auth/shopify/callback
Cloudflare Access	OTP email verification	Worker admin URLs (browser access)

COMPLETE ROUTE MATRIX

#	METHOD	PATH	AUTH	TYPE
1	GET	/health	None (public)	Health check
2	POST	/config	Bearer token	Admin
3	GET	/config	None (secrets masked)	Read-only
4	GET	/admin/tenants	Bearer token	Admin
5	GET	/auth/install	None (OAuth initiation)	OAuth
6	GET	/auth/callback	OAuth state verification	OAuth
7	GET	/embed/footer	None (public embed)	Embed
8	GET	/embed/compliance	None (public embed)	Embed
9	GET	/embed/account	None (public embed)	Embed
10	GET	/embed/dashboard	None (public embed)	Embed
11	GET	/setup	Admin key (query)	Admin UI
12	GET	/settings	Admin key (inside handler)	Admin UI
13	GET	/onboarding	Admin key (query)	Admin UI
14	GET	/onboarding/setup	Admin key (query)	Admin UI
15	POST	/onboarding/auto-setup	Bearer token	Admin
16	GET	/auth/webflow/connect	None (OAuth initiation)	OAuth
17	GET	/auth/webflow/callback	OAuth state verification	OAuth
18	GET	/api/xano/actions	None (public manifest)	Read-only
19	POST	/auth/signup	None (registration)	Auth
20	POST	/auth/login	None (login)	Auth

#	METHOD	PATH	AUTH	TYPE
21	GET	/auth/me	JWT (inside handler)	User
22	POST	/auth/logout	None (clears cookie)	Auth
23	GET	/auth/google/login	None (OAuth initiation)	OAuth
24	GET	/auth/google/callback	OAuth state verification	OAuth
25	GET	/auth/shopify/login	None (OAuth initiation)	OAuth
26	GET	/auth/shopify/callback	PKCE verification	OAuth
27	POST	/auth/profile	JWT (inside handler)	User
28	POST	/auth/delete-account	JWT (inside handler)	User
29	POST	/auth/forgot-password	None (email-based)	Auth
30	GET	/auth/reset-password	Token in URL	Auth
31	POST	/auth/reset-password	Token in body	Auth
32	POST	/auth/consent-sync	None (see note)	Consent
33	GET	/ucp/consent-history	JWT (inside handler)	User
34	POST	/ucp/tags	JWT (inside handler)	User
35	POST	/ucp/translate	JWT (inside handler)	User
36	POST	/segment/search	JWT (inside handler)	User
37	GET	/segment/stats	JWT (inside handler)	User
38	POST	/segment/count	JWT (inside handler)	User
39	POST	/webhooks/customer-update	HMAC-SHA256	Webhook
40	POST	/webhooks/customer-create	HMAC-SHA256	Webhook
41	POST	/webhooks/webflow-item-changed	Webflow webhook	Webhook

#	METHOD	PATH	AUTH	TYPE
42	POST	/api/webhooks	HMAC-SHA256	Webhook
43	POST	/gdpr/customer-redact	HMAC-SHA256	GDPR
44	POST	/gdpr/data-request	HMAC-SHA256	GDPR
45	POST	/gdpr/shop-redact	HMAC-SHA256	GDPR
46	GET	/tags	JWT (inside handler)	User
47	GET	/tags/user	JWT (inside handler)	User
48	POST	/tags/user	JWT (inside handler)	User
49	POST	/tags/create	Bearer token	Admin
50	POST	/admin/init-tag-system	Bearer token	Admin
51	POST	/admin/xano-schema	Bearer token	Admin
52	POST	/admin/xano-reseed	Bearer token	Admin
53	POST	/admin/adobe-schema	Bearer token	Admin
54	POST	/webhooks/upsell	Bearer token	Admin
55	POST	/admin/register-webhooks	Bearer token	Admin
56	POST	/admin/webflow-ensure-fields	Bearer token	Admin
57	POST	/admin/webflow-sync-test	Bearer token	Admin
58	GET	/admin/webflow-test	Bearer token	Admin
59	GET	/admin/shopify-customers	Bearer token	Admin
60	GET	/admin/shopify-test	Bearer token	Admin
61	POST	/sync/customers	Bearer token	Admin
62	POST	/sync/webflow	Bearer token	Admin

#	METHOD	PATH	AUTH	TYPE
63	GET	/admin/tenants	Bearer token	Admin
64	GET	/platform/config	Bearer token	Admin
65	POST	/platform/config	Bearer token	Admin
66	POST	/admin/provision-region	Bearer token	Admin
67	POST	/admin/adobe-schema	Bearer token	Admin

NOTES

- `/auth/consent-sync` (#32): Called from client-side embed scripts with `user_id` in body. The handler writes to Xano consent_records. This endpoint accepts unauthenticated requests from the embed context – consent changes from the cookie banner and compliance page arrive here. This is by design (the embed runs before the user has a JWT session), but the endpoint should be hardened with rate limiting.
- `GET /config` (#3): Returns config with all secrets masked (first 4 + last 4 chars). No auth required for read, but secrets are never exposed.
- **Embeds (#7-10):** Public HTML endpoints. Secrets are stripped via `getPublicCrmConfig()` before injection.

1.2 Fixes Applied (2026-05-17)

ROUTE	BEFORE	AFTER
POST /admin/init-tag-system	Open	Bearer token
POST /admin/xano-schema	Open	Bearer token
POST /admin/xano-reseed	Open	Bearer token
POST /admin/register-webhooks	Open	Bearer token
POST /admin/webflow-ensure-fields	Open	Bearer token
POST /admin/webflow-sync-test	Open	Bearer token
GET /admin/webflow-test	Open	Bearer token
GET /admin/shopify-customers	Open	Bearer token
GET /admin/shopify-test	Open	Bearer token
POST /sync/customers	Open	Bearer token
POST /sync/webflow	Open	Bearer token
POST /tags/create	Open	Bearer token

2. PAIRED DATA REQUIREMENTS

2.1 System Pairs – CRM Sync (Webflow-Primary Gateway)

CRM Sync uses Webflow as its primary headless gateway and Shopify as the commerce data source. Data flows bidirectionally between 7 systems.

Webflow (Gateway) ↔ Worker ↔ Shopify (Commerce)

↓

Xano (Source of Truth)

↓

GA4 / Adobe AEP / Resend

2.2 Data Pair Matrix

Each pair defines: what data crosses the boundary, which direction, what trigger, and what security contract.

PAIR 1: SHOPIFY ↔ XANO (CUSTOMER IDENTITY)

FIELD	SHOPIFY SOURCE	XANO TABLE	DIRECTION
Email	customer.email	storefront_users.email	Shop Xano
First Name	customer.firstName	storefront_users.first_name	Shop Xano
Last Name	customer.lastName	storefront_users.last_name	Shop Xano
Shopify GID	customer.id	storefront_users.shopify_gid	Shop Xano
Orders Count	customer.numberOfOrders	storefront_users.number_of_orders	Shop Xano
Total Spent	customer.totalSpentV2.amount	storefront_users.amount_spent	Shop Xano
Country	customer.defaultAddress.countryCodeV2	storefront_users.country	Shop Xano
Tags	customer.tags	user_tag_map (join table)	Bi- direc
Metafields	customer.metafields (crm_*)	Derived from tags	Xano Shop

Security: HMAC-SHA256 on webhooks. Admin token (shpua_) for GraphQL. Token auto-refreshed before 60-min expiry.

PAIR 2: XANO ↔ WEBFLOW CMS (CUSTOMER PROFILES)

FIELD	XANO SOURCE	WEBFLOW CMS FIELD	DIRECTION
Name	storefront_users.full_name	name (required)	Xano → Webflow
Email	storefront_users.email	email	Xano → Webflow
First/Last Name	storefront_users.first_name/last_name	first-name , last-name	Xano → Webflow
Provider	storefront_users.provider	provider	Xano → Webflow
Status	Derived from tags	status	Xano → Webflow
Tags (flat)	storefront_users.tags	tags	Xano → Webflow
Tag Refs	user_tag_map	tag-refs (ItemRefSet)	Xano → Webflow
Consent fields	user_claims.*	consent-tos/privacy/cookie/marketing	Xano → Webflow
Commerce	storefront_users.*	number-of-orders , amount-spent , country	Xano → Webflow
Shopify ID	storefront_users.shopify_gid	shopify-customer-id	Xano → Webflow
Adobe fields	user_extras.*	adobe-ecid/email-hash/sync-status/last-synced/identity-graph-id	Xano → Webflow
CMS edits	Webflow CMS item	storefront_users.*	Webflow → Xano

Security: Webflow CMS token via OAuth. Webflow webhook verified via state nonce.

PAIR 3: XANO ↔ GA4 (ANALYTICS EVENTS)

EVENT	DATA SENT	DIRECTION	TRIGGER
crm_tags_updated	tags_added, tags_removed, crm_status, crm_tier, crm_segment	Xano → GA4	Tag mutation
crm_sync	source, synced count	Xano → GA4	Cron sync
crm_form_submit	form_type, email (DataLayer only)	Client → GA4	Form bridge
crm_upsell	upsell_source, product_count, total_value	Xano → GA4	Upsell event
User Properties	crm_status, crm_tier, crm_segment, crm_tags, crm_campaign, consent_marketing, consent_tos	Xano → GA4	Any mutation

Security: GA4 API Secret stored in KV config. No PII sent — only tag categories and consent state. Client ID format: `crm-sync.{userId}`.

PAIR 4: XANO ↔ ADOBE AEP (CDP STREAMING)

FIELD	XANO SOURCE	XDM PATH	DIRECTION	TRIGGER
Email (hashed)	SHA-256(email)	identityMap.Email[0].id	Xano → AEP	Customer update
Phone (hashed)	SHA-256(phone)	identityMap.Phone[0].id	Xano → AEP	Customer update
Name (hashed)	SHA-256(name)	_shopifyCrmSync.hashizedName	Xano → AEP	Customer update
Consent	Derived from tags	consents.marketing.email/push , consents.adID , consents.personalize	Xano → AEP	Tag mutation
Subscriptions	Derived from tags	_shopifyCrmSync.subscriptions.{type}	Xano → AEP	Form bridge
Commerce	Product list	commerce.productListAdds , productListItems[]	Xano → AEP	Upsell event
ECID	AEP response	user_extras.adobe_ecid	AEP → Xano	Sync result
Sync status	Sync result	user_extras.adobe_sync_status	Worker → Xano	After push

Security: Adobe IMS OAuth (client_credentials). PII hashed with SHA-256 via Web Crypto API before transmission. Raw PII never leaves the worker. IMS tokens cached in KV with TTL.

PAIR 5: XANO ↔ RESEND (TRANSACTIONAL EMAIL)

EMAIL TYPE	DATA SENT	DIRECTION	TRIGGER
Welcome	email, name, set-password link (24h token)	Xano → Resend	New Shopify-origin user
Password Reset	email, reset link (1h token)	Xano → Resend	Forgot password

Security: Resend API key stored as wrangler secret. Reset tokens are KV-stored with TTL, single-use.

PAIR 6: WORKER ↔ CLOUDFLARE KV (CONFIG & STATE)

KEY PATTERN	DATA	SENSITIVITY	TTL
<code>tenant:{shop}:config</code>	Full CrmSiteConfig with all credentials + admin_key	HIGH	Persistent
<code>tenant:{shop}:tag_table_ids</code>	Xano table IDs (crm_tags + user_tag_map)	LOW	Persistent
<code>tenant: {shop}:webflow_tags_collection_id</code>	Webflow CRM Tags collection ID	LOW	Persistent
<code>tenant: {shop}:sync:customers:last_run</code>	ISO timestamp of last cron sync	LOW	Persistent
<code>tenants:index</code>	<code>TenantEntry[]</code> (shop, region, registered_at)	LOW	Persistent
<code>platform:config</code>	Shared platform credentials	HIGH	Persistent
<code>adobe_token:{shop}</code>	Adobe IMS access token	HIGH	~24h
<code>pkce:{state}</code>	PKCE code_verifier	MEDIUM	5 min
<code>oauth_state:{uuid}</code>	OAuth state + shop (UUID-keyed, no global collisions)	MEDIUM	10 min
<code>reset:{token}</code>	Password reset metadata	MEDIUM	1h / 24h

Security: KV encrypted at rest (Cloudflare managed). Secrets masked in GET /config. Short TTLs on auth state.

2.3 Baseline Data Contract

Every data pair has the following contract:

1. **Identity resolution** — Email is the primary key across all systems (Shopify GID for Shopify-specific operations)
2. **Source of truth** — Xano is canonical. Conflicts resolved by most-recent-write-wins.
3. **PII boundary** — Raw PII stays within Worker + Xano + Shopify + Webflow CMS + Resend. GA4 and Adobe AEP receive hashed or categorized data only.

- 4. **Auth boundary** — Every cross-system call uses the target system's native auth (Shopify Admin token, Webflow CMS token, Xano API key, GA4 API secret, Adobe IMS OAuth, Resend API key).
- 5. **Tenant isolation** — Config and credentials are scoped to `tenant:{shop}:config` . No cross-tenant reads.
- 6. **Audit trail** — All consent mutations logged to `consent_records` (append-only). Adobe sync logged to `adobe_sync_log` .

3. REMAINING HARDENING ITEMS

#	ITEM	PRIORITY	STATUS
1	Rate limit <code>/auth/consent-sync</code>	Medium	Open
2	Rate limit <code>/auth/signup</code> and <code>/auth/login</code> (brute force)	Medium	Open
3	Rate limit <code>/auth/forgot-password</code> (email enumeration)	Medium	Open
4	Add <code>ADMIN_KEY</code> secret if not already set	Critical	Verify
5	Rotate Shopify refresh tokens before 90-day expiry	Low	Automated (cron)
6	Verify Cloudflare Access policy covers all admin URLs	Low	Verify
7	Add CSP headers to embed HTML responses	Low	Open
8	Add <code>X-Content-Type-Options: nosniff</code> to all JSON responses	Low	Open